

KOMPLEET Expense Tracking & Receipt OCR Codebase Audit Report

Auditor: Principal Engineer / Product Auditor
Date: 2026-02-24
Branch Audited: release/expense-v1 (merged into main)
Reference: docs/EXPENSE_TRACKING_PRD_AND_EXECUTION_PLAN.md,
docs/EXPENSE_RELEASE_AND_QA_CHECKLIST.md

1. Executive Summary (Traffic-Light Status)

PRD Section	Status	Summary
Supabase Schema & Migrations	GREEN	All tables, RLS, seeds, storage policies present
RLS Policies	GREEN	Properly scoped to auth.uid() for all tables +
NDPR Consent Gating	GREEN	Consent gate blocks camera/sync until accepted
Offline-First Data Layer	GREEN	SQLite + sync_queue + ocr_queue fully
OCR Pipeline	YELLOW	Server fallback + parsing + offline queue present.
Expense Management UX	GREEN	Mobile list/edit/delete/categories/offline indicators.
Reports & Export	GREEN	Web: PDF/CSV/Excel. Mobile: CSV + share
Mileage Tracking	YELLOW	GPS start/end trip works. No
Premium Gating & Teams	GREEN	requirePremium gating + workspaces schema +
Secrets & Env Vars	GREEN	No secrets committed
Tests	YELLOW	54/55 pass. 1 failure: missing rollback migration
Expo/RN Health	GREEN	Expo 54, RN 0.81.5, React 19.1 aligned
Play Store Readiness	RED	Missing: location permission, privacy policy, data

2. What Is Complete

2.1 Supabase Schema & Migrations (Sprint 1 + Sprint 5)

- File: supabase/migrations/20260221000000_expense_tracking.sql Creates expenses, expense_categories, expense_reports, ndpr_consent with full RLS (select/insert/update/delete scoped to auth.uid()), storage policies for receipts bucket, updated_at trigger, and Nigerian default category seeds.
- File: supabase/migrations/20260221100000_sprint5_workspaces_premium.sql Adds subscription_tier to profiles, creates workspaces and workspace_members tables with RLS, adds optional workspace_id on expenses, seeds Mileage category.
- File: src/db/schema/expenses.ts Drizzle ORM type definitions for all tables including workspaceId on expenses and workspaces/workspaceMembers.

2.2 RLS Policies

- Expenses: per-operation policies (expenses_select, expenses_insert, expenses_update, expenses_delete) all use auth.uid() = user_id.
- Categories: system categories (user_id IS NULL) visible to all; custom scoped to owner.
- Reports & NDPR consents: FOR ALL with auth.uid() = user_id.
- Storage: receipts bucket scoped by (storage.foldername(name))[1] = auth.uid():text.
- Workspaces: owner full access; members select-only via subquery.
- Verified in migration SQL. Runtime RLS enforcement is Unverified requires test against live Supabase.

2.3 NDPR Consent Gating

- File: apps/mobile/lib/ndpr/NDPRConsentGate.tsx React context + modal gate that wraps the entire app in `_layout.tsx`. Children are not rendered until consent is given.
- File: apps/mobile/lib/ndpr/consent-store.ts Consent persisted in expo-secure-store locally + upserted to Supabase `ndpr_consents` when online.
- File: apps/mobile/app/(tabs)/scan.tsx Camera also double-checks `consent?.hasConsent` before launching.

2.4 Offline-First Data Layer

- File: apps/mobile/lib/db/schema.ts SQLite tables: `expenses` (with `sync_status`, `local_id`, `deleted` columns), `expense_categories`, `sync_queue`, `ocr_queue`, `sync_meta`.
- File: apps/mobile/lib/db/init.ts `initDb()` creates all tables synchronously and seeds 8 Nigerian default categories.
- File: apps/mobile/lib/db/expense-repository.ts `createExpense`, `updateExpense`, `deleteExpense` all write locally first and enqueue to `sync_queue`. Soft-delete pattern.
- File: apps/mobile/lib/sync/sync-engine.ts `runSync()`: push (drain `sync_queue` Supabase insert/update/delete) then pull (fetch expenses where `updated_at >= last_synced_at` upsert into SQLite). Last-write-wins via `updated_at`.

2.5 Expense Management UX

- Mobile Home: apps/mobile/app/(tabs)/index.tsx `FlatList` from SQLite, pull-to-refresh triggers sync, offline banner, "Pending sync" badges, long-press to delete, tap to edit.
- Mobile Edit: apps/mobile/app/receipt-edit/[id].tsx Full edit form with category picker (modal `FlatList`), receipt upload on save.
- Web List: src/app/(dashboard)/expenses/page.tsx Fetches from `/api/expenses`, date + category filters, pagination.
- Web Detail/Edit: src/app/(dashboard)/expenses/[id]/page.tsx Full CRUD with save and delete.
- Web API: src/app/api/expenses/route.ts (GET/POST), `[id]/route.ts` (GET/PATCH/DELETE), `categories/route.ts` (GET).
- Sidebar: Confirmed "Expenses" and "Expense Reports" nav links in Sidebar.tsx.

2.6 Reports & Export

- Web API: src/app/api/expenses/export/route.ts GET with `startDate`, `endDate`, `format` params. CSV (plain text), PDF (jsPDF + `autoTable`), Excel (ExcelJS). Proper Content-Disposition headers.
- Web Page: src/app/(dashboard)/reports/expense-reports/page.tsx Date range picker + 3 download buttons (CSV/PDF/Excel). Blob download.
- Mobile: apps/mobile/app/(tabs)/reports.tsx CSV export from SQLite via `listExpensesInRange()` + expo-sharing. Link to web for PDF/Excel.

2.7 Premium Gating & Teams

- File: src/lib/expense-premium.ts `getSubscriptionTier()` reads `profiles.subscription_tier`, `requirePremium()` returns 402 response.
- File: src/app/api/expenses/workspaces/route.ts GET/POST gated by `requirePremium`.
- File: src/app/api/expenses/billing/checkout/route.ts Returns 503 "Billing is disabled until legal review".
- Web UI: src/app/(dashboard)/expenses/teams/page.tsx Premium required message when 402.

2.8 Secrets & Env Vars

- No hardcoded secrets found in mobile or API expense code.
- Mobile uses `EXPO_PUBLIC_SUPABASE_URL`, `EXPO_PUBLIC_SUPABASE_ANON_KEY`, `EXPO_PUBLIC_API_URL` from env.
- Web uses `createServerClient()` from `@/lib/supabase/server` (reads server-side env vars).
- Logger (apps/mobile/lib/logger.ts) only logs in `__DEV__` mode.

2.9 Test Suite

- 54 of 55 tests pass across 7 test files.
- Covers: schema exports, migration file verification, API route existence/validation, OCR parsing (amounts, dates, vendors, VAT), sync contract, mobile file structure, sidebar nav, premium helper, billing stub, mileage components.

3. What Is Partially Complete

3.1 OCR Pipeline On-Device ML Kit Missing (YELLOW)

- What exists:
- Server-side OCR: `src/app/api/expenses/ocr/route.ts` uses `tesseract.js` to extract text, then `parseReceiptText()` for field extraction.
- Mobile OCR queue: `apps/mobile/lib/ocr/ocr-queue.ts` enqueue when offline, process via API when online.
- Receipt parser: `apps/mobile/lib/ocr/parse-receipt.ts` regex-based extraction for Nigerian receipts.
- Manual correction: `apps/mobile/app/receipt-edit/[id].tsx`.
- What's missing:
- `@react-native-ml-kit/text-recognition` is NOT in `apps/mobile/package.json` and not imported anywhere.
- Currently ALL OCR goes through the server API, defeating offline-first for OCR.
- Impact: OCR only works online. Offline scans are queued but not processed until reconnection.

3.2 Mileage Tracking Minimal Implementation (YELLOW)

- What exists:
- `apps/mobile/app/(tabs)/mileage.tsx` Start trip (get GPS), end trip (get GPS), compute haversine distance, save as expense.
- `apps/mobile/lib/mileage/distance.ts` Haversine formula.
- Uses `Location.Accuracy.Low` for battery efficiency.
- What's missing:
- No continuous/background location tracking. Only captures start and end points.
- No background location permissions declared in `app.json`.
- Impact: Mileage accuracy poor for non-straight routes. Adequate for MVP if documented.

3.3 Tests 1 Failure (YELLOW)

- `tests/expense-sprint5.test.ts` > "Sprint 5 rollback migration exists" FAILS.
- Expects `supabase/migrations/20260221100001_sprint5_workspaces_premium_rollback.sql` but file does not exist.
- Impact: Minor fix by creating rollback file or removing the test.

3.4 Mobile Auth Placeholder User ID (YELLOW)

- File: `apps/mobile/lib/auth/user-id.ts` Uses `SecureStore` key or fallback `EXPO_PUBLIC_TEST_USER_ID` / "local-user".
- `getSupabaseClient()` creates a new client each call with no session management.
- Impact: Mobile is not wired to real Supabase Auth sessions. Sync and uploads will fail in production. Release blocker.

4. What Is Missing

Item	Detail
On-device OCR (ML Kit)	<code>@react-native-ml-kit/text-recognition</code> not installed
Sprint 5 rollback migration	File does not exist
"Delete Account" flow	Not implemented anywhere
Privacy Policy URL	Not configured in <code>app.json</code>
Location permissions in <code>app.json</code>	<code>ACCESS_FINE_LOCATION</code> , <code>ACCESS_COARSE_LOCATION</code> missing
Dark mode (mobile)	Hardcoded light colors, no <code>useColorScheme()</code>
Network state monitoring	No <code>expo-network</code> / <code>NetInfo</code> dependency
Conflict resolution UI	No "Keep mine / Keep server" last-write-wins only
Onboarding flow	No demo scan / first expense / first export screens

5. High-Risk Issues (Blockers to Release)

#	Issue	Severity	Path
1	Mobile auth is a placeholder sync,	CRITICAL	apps/mobile/lib/auth/user-id.ts,
2	No on-device OCR offline scans	HIGH	Missing from
3	No "Delete Account" flow Google	HIGH	Not implemented
4	Location permission missing from	HIGH	apps/mobile/app.json

6. Security & Compliance Gaps

#	Check	Status
1	No secrets committed in expense code	PASS
2	Logger suppresses output in production	PASS
3	NDPR consent captures scan + cloud sync	PASS
4	Consent stored locally (SecureStore) + Supabase	PASS
5	RLS policies scope all tables to auth.uid()	PASS (SQL verified; runtime Unverified)
6	Storage RLS scopes receipts by user folder	PASS
7	Account deletion flow (NDPR data subject rights)	FAIL
8	Privacy policy URL configured	FAIL
9	SQLite encrypted at rest	ACCEPTABLE for MVP
10	Mobile auth real session tokens	FAIL RLS bypass risk

7. Performance & Stability Risks

#	Risk	Impact	Mitigation
1	getSupabaseClient() creates new	Memory/connection leak	Singleton pattern
2	OCR API uses Tesseract.js in	OCR latency	Consider Cloud Vision or
3	Mileage is point-to-point only	Inaccurate for non-straight routes	Acceptable for MVP if documented
4	No NetInfo connectivity check via	Unreliable offline detection	Add expo-network
5	Pending receipt image in	Lost on crash	Store URI in SQLite
6	No image compression before	Large payloads on slow networks	Add resize/compress step

8. Play Store Readiness Gaps

Requirement	Status
App ID stable (com.kompleet.platform)	PASS
Version/versionCode (0.1.0 / 1)	PASS
EAS project linked	PASS
Camera permission explained	PASS
Location permission declared	FAIL
Privacy Policy URL	FAIL
Data Safety form completed	FAIL
Delete Account flow	FAIL

Debug logs suppressed in prod	PASS
No test endpoints in prod	PASS
Screenshots & feature graphic	FAIL
Short/full description	FAIL
Unused RECORD_AUDIO permission	WARNING will raise review questions

9. Concrete Next Actions (Priority-Ordered)

Priority	Action	Files to Change
P0	Wire mobile Supabase Auth real sign-in/sign-up,	apps/mobile/lib/auth/user-id.ts,
P0	Add expo-location plugin + permissions to	apps/mobile/app.json
P0	Implement "Delete Account" flow	New settings screen + API route
P0	Add Privacy Policy URL	apps/mobile/app.json, Play Console
P1	Install @react-native/ml-kit/text-recognition and	apps/mobile/package.json, new on-device-ocr.ts,
P1	Create Sprint 5 rollback migration or fix failing	supabase/migrations/ or
P1	Add expo-network for reliable connectivity	apps/mobile/package.json, sync triggers
P2	Implement dark mode on mobile	All mobile screen files
P2	Persist pending receipt URI in SQLite	apps/mobile/lib/receipt-pending-image.ts
P2	Singleton Supabase client	apps/mobile/lib/supabase/client.ts
P2	Add image compression before OCR	apps/mobile/lib/ocr/
P3	Prepare Play Store listing assets	New apps/mobile/store-assets/
P3	Complete Data Safety declaration	Play Console (manual)
P3	Add onboarding screens	New apps/mobile/app/onboarding/

10. Recommended Release Readiness Decision

NO-GO

Rationale:

The expense tracking feature has substantial code coverage across all 5 sprints schema, offline layer, sync engine, OCR pipeline, export, premium gating, and mileage are all implemented. 54 of 55 tests pass. The architecture is sound and matches the PRD.

However, there are 4 critical blockers that prevent a production release or Play Store submission:

1. Mobile auth is a placeholder without real Supabase Auth sessions, the sync engine, receipt uploads, and all RLS-protected operations will fail in production.
2. No "Delete Account" flow hard requirement for Google Play since 2024.
3. Location permission not declared mileage feature will malfunction.
4. No Privacy Policy URL Play Store submission will be rejected.

Recommended path to GO:

1. Fix P0 items (estimated 23 days of focused work)
2. Run full QA pass on Android device/emulator
3. Complete Play Store listing (screenshots, Data Safety form)
4. Re-run this audit against the updated code